

1. ASSESSMENT CATEGORIES

The major categories in the SAQ
(Self-Assessment
Questionnaire).



ASSESSMENT

ASSESSMENT CATEGORIES

In terms of assessing yourself, as an organization for PCI-DSS, there are two approaches:

- Self-Assessment Questionnaire (SAQ);
- A Report on Compliance (ROC);

The major difference is:

- SAQs are performed by the organization itself, are simpler and faster;
- ROCs must be performed by a Qualified Security Assessor (QSA);

The criterion defining whether an organization needs a ROC (or, on the other hand, whether a SAQ is acceptable) is being a Level 1 Merchant (Having over 6M transactions per year)

ASSESSMENT

ASSESSMENT CATEGORIES

Merchants can be of four levels (from big to small):

- Level 1:
 - >6M transactions per year;
- Level 2:
 - 1M< transactions <6M per year;
- Level 3:
 - 20k< transactions <1M per year;
- Level 4:
 - <20k transactions per year;

As mentioned, merchants from Level 2 through 4 can perform an SAQ (submitted to their acquiring bank), while Level 1 merchants must take a ROC, performed by a QSA.





ASSESSMENT

ASSESSMENT ASSESSMENT CATEGORIES

For merchants Level 2 to 4, taking the SAQ is not that simple, as there are 9 SAQ versions available, depending on the type of organization, and how they handle CHD:

- Card Not Present (CNP) handling:
 - SAQ A (fully outsourced payments)
 - SAQ A-EP (partially outsourced payments);
 - SAQ C (payment apps connected to the Internet);
 - SAQ C-VT (isolated virtual payments - mail/telephone);
- Card Present (CP) handling:
 - SAQ B (imprint machines/terminals only);
 - SAQ B-IP (PTS-approved terminals, IP connected);
 - SAQ SPoC (PCI SSC-approved off-the-shelf solution);
- CP or CNP:
 - SAQ P2PE (only hardware terminals managed by P2PE);
 - SAQ D-Service Providers (machine providers, etc);
 - SAQ D-Merchants (all merchants not SAQ A through C);

ASSESSMENT

ASSESSMENT CATEGORIES

Different SAQ types demand compliance with different requirements, as well as a different total number of total sub-requirements to comply with:

- A: Reqs 2, 3, 6, 8, 9, 11 12 31 sub-reqs.
- A-EP: All 151 sub-reqs.
- B: Reqs 3, 7, 9, 12 27 sub-reqs.
- B-IP: All but 5, 10 49 sub-reqs.
- C: All 132 sub-reqs.
- C-VT: All but 10, 11 54 sub-reqs.
- D: All 252 sub-reqs.
- P2PE: Reqs 3, 9, 12 21 sub-reqs.
- SPoC: Reqs 3, 8,9, 12 22 sub-reqs.





ASSESSMENT

ASSESSMENT CATEGORIES

The different categories can also be simplified in terms of explanation:

- A: E-commerce merchants, fully outsourced. All card processing is done with iFrames/redirects to 3rd parties;
 - The most straightforward SAQ. Merchants aim to be this;
- A-EP: E-commerce merchants partially outsourcing payment processing. CHD are not stored, but conveyed;
 - Using “POST” forms to redirect;
- B: Dial-out merchants (chip/PIN device connected to phone) or imprint machines (carbon copy). No storage;
 - Physical security of machines/paper copies is the focus;
- B-IP: Standalone chip devices that only have an IP connection. Focus on everything but AV and pentesting;

ASSESSMENT

ASSESSMENT CATEGORIES

- C: Payment app systems connected to the Internet. The payment processing is in the device itself. No storage;
- C-VT: Web-based virtual terminals (call center/face-to-face transaction with direct entry of payment). No CHD storage;
 - The device must be isolated in the network;
- D: All other merchants, and all payment provider brands;
 - Any merchant that stores data immediately lands here (e-commerce merchants are usually A, A-EP, or D);
- P2PE: Merchants with only hardware payment terminals (PCI-validated P2PE chip/PIN device)
 - No CHD storage. Can be CP or not;
- SPoC: Similar, but off-the-shelf solutions for CP environments.





ASSESSMENT

ASSESSMENT **ASSESSMENT CATEGORIES**

It's important to note that an organization may meet multiple criteria for multiple SAQs, and must take all of the corresponding SAQs in that case. This is completely normal.

Selecting the wrong SAQ for an organisation, however, may result in failing PCI-DSS compliance (resulting in consequences ranging from compensating controls to fines or even removal of payment brand association), or just wasting time filling the wrong SAQ (the number of questions can range from ~30 to around ~300).

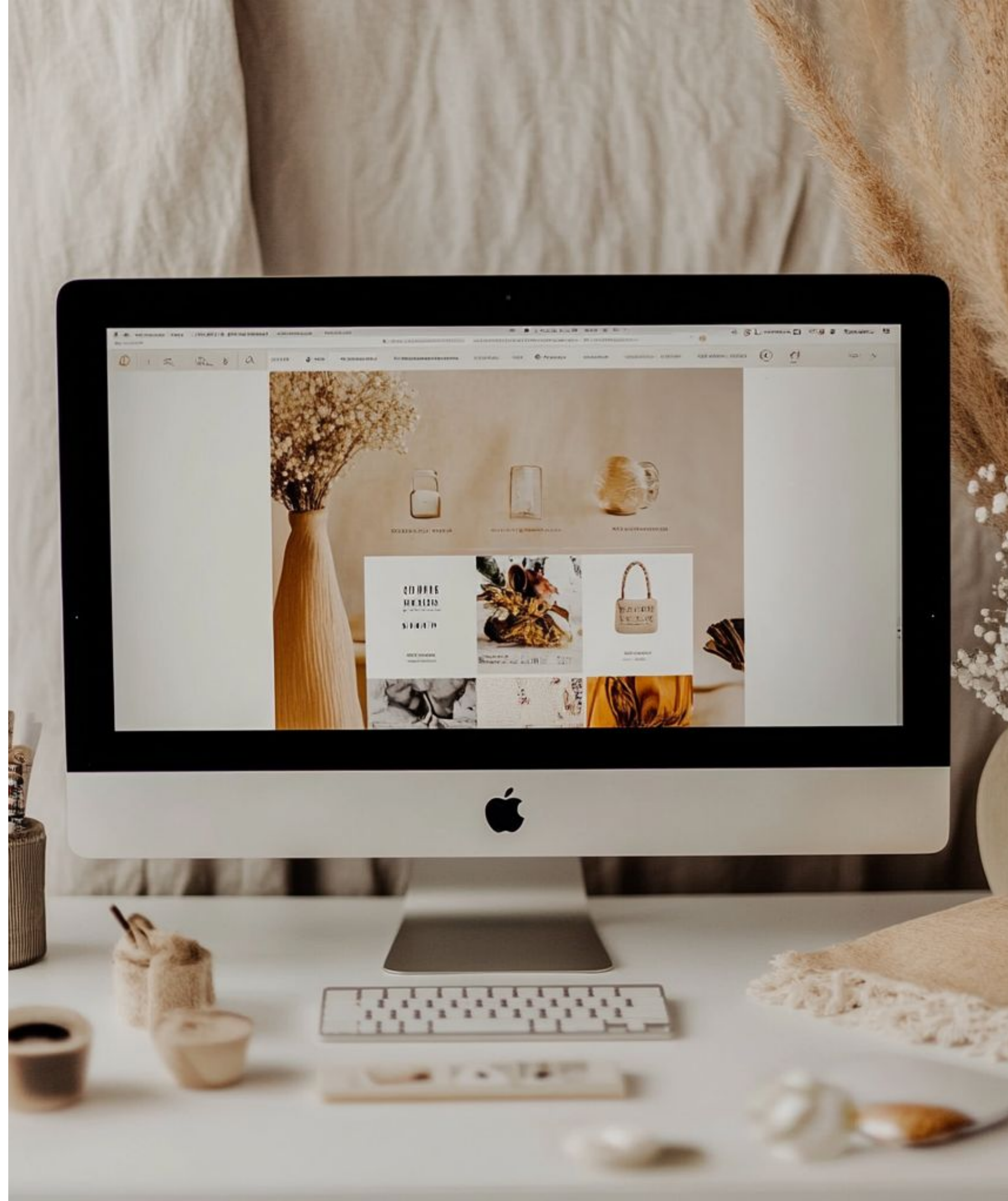
ASSESSMENT

ASSESSMENT CATEGORIES

Let's cover some specific examples, starting with SAQ-A:
Card-Not-Present merchants, where all payment processing is fully outsourced:

- An example could be a small, online clothing store that redirects customers to a third-party payment processor, such as PayPal or stripe. The store doesn't handle, store or transmit cardholder data at all;
- Or, for example, a mail-order subscription box service that takes orders online, or via Apple subscriptions, and that uses a third-party payment gateway (PayPal, Apple Store Payments) to process all payments;





ASSESSMENT

ASSESSMENT CATEGORIES

SAQ A-EP (E-commerce merchants that use third-party payment processors, but that do manage web pages):

- An example could be a fashion brand's website, that allows users to browse and select items, but payment processing is with a third-party (such as Stripe). But the website is still hosted by the merchant;
- Or, for example, a ticket booking site that handles all user interaction (choosing seats, filling out details), but redirect to an external payment processor for actual payment;
- (In the case of these, there is no vulnerability with the payment processor itself, but the integration between the website and the payment processor);

ASSESSMENT

ASSESSMENT CATEGORIES

SAQ-B (Merchants with standalone, dial-out payment terminals):

- An example could be a coffee shop with a dial-out point of sale (PoS) terminal for in-person transactions, that connects directly to a payment processor without storing any cardholder data;
- Or, for example, a small gas station that uses standalone dial-out terminals for card payments at the pump or at the counter, that, again, connect directly to a payment processor without storing data;





ASSESSMENT

ASSESSMENT CATEGORIES

SAQ B-IP (Merchants that use IP-connected payment terminals):

- An example could be a coffee shop that uses an IP-connected terminal, to process payments over the Internet (a sophisticated payment terminal with an associated tablet, allowing e-mail invoices, multiple payment methods, etc), but that doesn't store any cardholder data;
- Or a restaurant that uses a network-connected PoS system to process payments in-store, but where the payment data are directly transmitted to a payment processor;

ASSESSMENT

ASSESSMENT CATEGORIES

SAQ-C (Merchants with payment systems connected to the Internet):

- An example could be a mid-sized retail store that uses an integrated payment terminal, connected to their network for payment processing, but that doesn't store cardholder data themselves;
- Or, for example, a restaurant chain that uses internet-connected PoS systems for card payments, not storing CHD after the transaction;





ASSESSMENT

ASSESSMENT

ASSESSMENT CATEGORIES

SAQ C-VT (Merchants using Virtual Terminals on a PC):

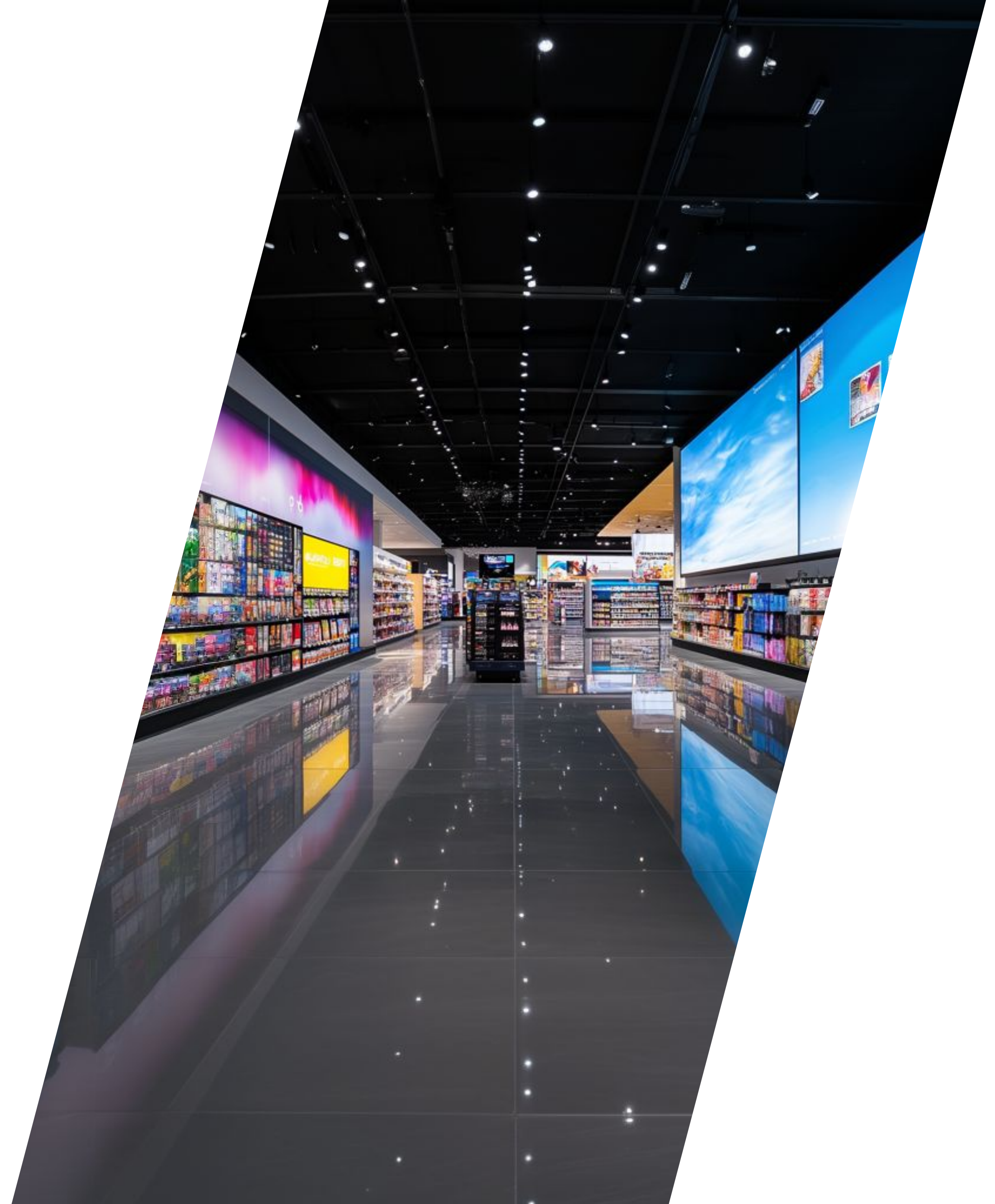
- An example could be a dentist's office, processing payments over the phone via a virtual terminal, browser-based, that doesn't store cardholder data;
- Or, for example, a small accounting firm that accepts credit card payments from clients, using a virtual terminal on PC, processing individual payments without storing card information;

ASSESSMENT

ASSESSMENT CATEGORIES

SAQ-D (Merchants and service providers that handle cardholder data):

- An example could be a large e-commerce retailer that processes and stores cardholder data, to facilitate future transactions or loyalty programs;
- Another example could be a payment gateway service provider which stores, processes, and transmits cardholder data for multiple merchants, handling a high volume of transactions;





ASSESSMENT

ASSESSMENT

ASSESSMENT CATEGORIES

SAQ P2PE (Peer-to-peer encrypted machines):

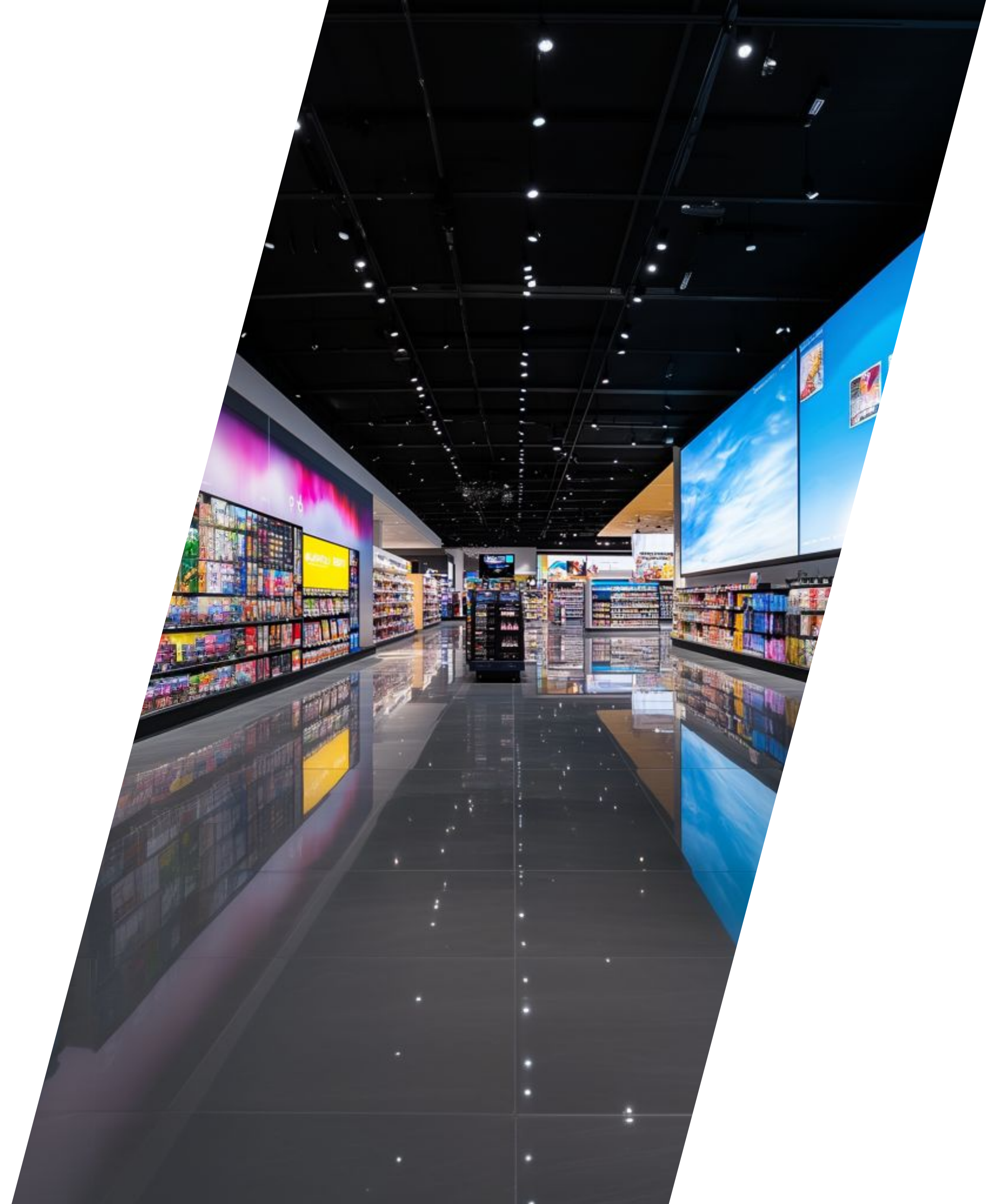
- An example could be a furniture store that uses a P2PE solution at the checkout, with a PCI-approved POI, where all card data are encrypted from moment of capture until they reach the processor, with no access to, or storage of, card data;
- Another example could be a luxury hotel that uses a P2PE system for payments at the front desk, with encrypted card transactions that prevent any direct handling of card data;

ASSESSMENT

ASSESSMENT CATEGORIES

SAQ-SPoC (Merchants with custom off-the-shelf devices with a PCI-listed secure card reader/PIN (SCRP) device for Card Present interactions):

- An example could be a food truck that uses a mobile phone or table to process payments with a validated SCRCP device. Customers present their card and enter the PIN, and the merchant uses the card reader to process the payment;
- Another example could be an on-the-go service provider, such as an electrician or plumber, who visits the client on-site and uses a table or phone connected to an SCRCP device to securely process the payments. Customers have their card read and enter the PIN as well;



ASSESSMENT

ASSESSMENT CATEGORIES

EXAMPLES

/01 VALIDATION REQUIRED

If banks have suspicions of specific merchant clients (or if they want to be extra sure), they may request the SAQ to be validated by a QSA.

/02 A, A-EP OR D

Depending on their activities, CNP merchants usually fill SAQ A (fully outsourced), A-EP (outsourced but transmit data) or D (store cardholder data).

/03 TRANSACTIONS, NOT VALUE

Level 1 merchants need to have over 6M in transactions. This is not dictated by the transaction value, but the volume itself. May be \$1M or \$1.

ASSESSMENT

ASSESSMENT CATEGORIES

KEY TAKEAWAYS

/01 ROC OR SAQ

Merchants can be of 1 of 4 levels, and only Level 1 merchants (>6M transactions) must take an ROC. All others take an SAQ.

/03 DIFFERENT REQUIREMENTS

Depending on the SAQ they fill, merchants may not have to comply with all 12 PCI-DSS requirements. This has to do with their types of systems and networks.

/02 9 DIFFERENT SAQs

Depending on their activities, merchants take one of 8 different SAQ types. The most extensive, “miscellaneous” one is the SAQ-D.